Preventing Software Supply Chain Failures

- **Track dependencies:** Maintain a Software Bill of Materials (SBOM), including transitive dependencies
- **Monitor vulnerabilities:** Continuously scan components and track CVEs
- **Patch regularly:** Update vulnerable dependencies and development tools
- **Use trusted sources:** Prefer official repositories and signed packages
- **Secure CI/CD:** Enforce MFA, least privilege, code reviews, and separation of duties
- **Ensure integrity:** Sign builds, verify provenance, and protect artifacts
- **Control changes:** Track modifications to repositories, pipelines, and dependencies
- **Limit exposure:** Remove unused components and use staged deployments

A04 - Cryptographic Failures

➡ **Problem:** Weak or improperly implemented cryptography exposes sensitive data

◉ **Impact:** Data disclosure, credential theft, or compromised communications

Common vulnerabilities:

- **Insufficient Transport protection:** sensitive data transmitted without authentication and encryption
- **Password storage:** weak or unsalted password hashing